

COMPUTER NETWORKING & CYBER SECURITY

CASE STUDY REPORT

Case Study No. 154

Vaseworth Glassblowing Studio & Gallery

Security Assessment, Firewalls, VPN & Hardening

Student Name	Akhila Anish Das
Roll No.	150096725016
Cohort	Larry Page
Program	B.Tech CSE 2025–2029
Semester	3
Sprint	1
Subject	Computer Networking & Cyber Security

Submitted as part of the Computer Networking & Cyber Security case study.

1. Introduction

Vaseworth Glassblowing Studio & Gallery operates a Head Office and three gallery locations connected through the public Internet. The organization maintains an online gallery and commission-order system and therefore depends on secure and reliable network communication.

During the last month, the IT security team identified four security incidents involving ARP behavior, denial of service, phishing and insecure remote management. These incidents represent risks to Confidentiality, Integrity and Availability (CIA).

This report identifies the attacks, maps them to the CIA triad, recommends a firewall architecture, designs site-to-site IPSec VPN connections, provides device-hardening guidance, proposes separate staff and guest wireless networks, and provides a staff-awareness note.

2. Problem Statement

Vaseworth's Head Office and three galleries communicate over the public Internet. The observed incidents demonstrate weaknesses in Layer-2 protection, Internet-facing service protection, credential security and management-plane security. The organization therefore requires a practical security improvement plan based on the networking and cybersecurity concepts covered in the course.

3. Objectives

- Identify the CIA triad impact and attack technique for each observed incident.
- Recommend a firewall architecture using stateful firewall and NGFW technologies, including placement and cost/risk justification.
- Design site-to-site IPSec VPN connections between Head Office and each gallery, including IKE Phase 1 and Phase 2 parameters.
- Develop a device-hardening checklist covering SSH, AAA, warning banners, insecure services and Layer-2 protection.
- Design separate secure wireless networks for staff and visitors.
- Prepare a short non-technical staff-awareness note addressing phishing.

4. Security Concepts Used

4.1 CIA Triad

Confidentiality ensures that information is accessible only to authorized users. **Integrity** ensures that information and network communication are not improperly modified or manipulated. **Availability** ensures that systems and services remain accessible to authorized users when required.

4.2 Defense in Depth

Vaseworth should not depend on a single security control. Firewalls, VPN encryption, device hardening, Layer-2 controls, VLAN separation, wireless security and staff awareness should work together as multiple layers of defense.

5. Incident-to-CIA-Triad Mapping

Incident	Attack Technique	CIA Impact	Why
1. Gateway IP mapped to two MAC addresses	ARP Spoofing / MITM	Integrity; potentially Confidentiality	The attacker can manipulate ARP mappings and redirect traffic through the attacker's device, allowing traffic interception or modification.
2. Huge burst of half-open TCP connections	SYN Flood / DoS	Availability	Many SYN requests remain incomplete, consuming server resources and preventing legitimate users from accessing the service.

Incident	Attack Technique	CIA Impact	Why
3. Employee entered credentials on fake IT portal	Phishing / Credential Compromise	Confidentiality	The attacker obtains credentials that should only be known by authorized personnel.
4. Administrator credentials readable over Telnet	Cleartext Management Traffic Exposure	Confidentiality	Telnet exposes management information in an insecure form, allowing a network observer to capture credentials.

6. Detailed Incident Analysis

6.1 Incident 1 – ARP Spoofing / Man-in-the-Middle

The gallery switch's ARP table showed the default-gateway IP address associated with two different MAC addresses within a short period. This strongly indicates suspicious ARP activity.

ARP is used to associate an IP address with a MAC address on a local network. An attacker can send forged ARP information claiming that the gateway IP belongs to the attacker's MAC address. If accepted, traffic intended for the gateway can be redirected through the attacker.

CIA impact: Integrity is primarily affected because the expected IP-to-MAC relationship is manipulated. Confidentiality may also be affected if redirected traffic is intercepted.

Controls: port security, MAC restrictions, DHCP snooping where applicable, VLAN separation, secure switch configuration and monitoring of abnormal Layer-2 behavior.

6.2 Incident 2 – SYN Flood

The online gallery and commission-order server became unreachable after a large burst of half-open TCP connections. This is characteristic of a SYN flood, a denial-of-service technique.

TCP normally uses a three-way handshake: SYN, SYN-ACK and ACK. In a SYN flood, an attacker sends many SYN requests without completing the connection. Server resources can become exhausted by these incomplete sessions.

CIA impact: Availability is the primary affected property.

Controls: NGFW protection, stateful inspection, SYN-flood/DoS protection, access-control policies and monitoring of abnormal connection patterns.

6.3 Incident 3 – Phishing / Credential Compromise

A gallery associate clicked an email impersonating IT support and entered credentials into a fake portal. This is a phishing attack leading to credential compromise.

CIA impact: Confidentiality is primarily affected because credentials are disclosed to an unauthorized party.

Controls: staff awareness, phishing recognition, strong authentication, AAA, secure login mechanisms and verification of suspicious IT requests through approved channels.

6.4 Incident 4 – Telnet Cleartext Exposure

A contractor was able to read an administrator's login typed over Telnet. Telnet is unsuitable for secure network management because it does not provide adequate encryption for management traffic.

CIA impact: Confidentiality is primarily affected.

Control: disable Telnet and use SSH for encrypted remote management.

7. Proposed Security Architecture

The proposed architecture places an NGFW at the Internet-facing edge, uses controlled stateful firewalling for predictable internal/site traffic, establishes IPsec VPN tunnels between Head Office and each gallery, and separates staff and guest wireless networks using VLANs.

Logical placement: Public Internet → NGFW → public-facing web/commission services and Head Office security boundary. Head Office then connects to Gallery 1, Gallery 2 and Gallery 3 through separate site-to-site IPSec VPN tunnels. Each gallery uses separate Staff and Guest VLANs.

8. Firewall Architecture Recommendation

8.1 Stateful Firewall

A stateful firewall tracks active network sessions and can determine whether traffic belongs to an established, legitimate connection. It is suitable for predictable gallery-to-HQ traffic and controlled internal communication where advanced application inspection is not required.

8.2 Next-Generation Firewall

An NGFW is recommended at the Internet-facing edge because the online gallery and commission-order services are exposed to public Internet traffic and were specifically affected by a SYN-flood incident. The NGFW provides more advanced traffic inspection and security capabilities than basic stateful filtering.

8.3 Cost and Risk Justification

Using an NGFW at every location would increase cost and administrative complexity. A risk-based split places stronger protection at the highest-exposure Internet edge while using stateful controls for predictable lower-risk site traffic. This provides stronger protection where risk is greatest without unnecessarily deploying expensive equipment everywhere.

Location	Recommended Control	Reason
Internet-facing gallery portal	NGFW	Highest exposure to Internet-based attacks.
Commission-order web service	NGFW protection	Public-facing business service with availability and security requirements.
HQ-to-gallery traffic	Stateful firewall + IPSec	Predictable traffic protected by an encrypted site-to-site tunnel.
Switches	Switch security controls	Reduce Layer-2 attack opportunities.
Staff Wi-Fi	WPA3 + Staff VLAN	Protect internal users and resources.
Guest Wi-Fi	Separate Guest VLAN	Prevent visitors from reaching internal resources.

9. Site-to-Site IPSec VPN Design

Each gallery should establish an IPSec VPN tunnel with the Head Office. The public Internet remains the underlying transport, but business traffic is protected by authenticated and encrypted VPN security associations.

Connections: HQ ↔ Gallery 1; HQ ↔ Gallery 2; HQ ↔ Gallery 3.

9.1 IKE Phase 1 Parameters

Parameter	Recommended Value	Purpose
Authentication	Pre-Shared Key (PSK)	Authenticates VPN peers.
Encryption	AES-256	Protects confidentiality during negotiation.
Hash / Integrity	SHA-256	Provides integrity/authentication support.
DH Group	Group 14	Provides secure key exchange.
Lifetime	86400 seconds	Limits how long the Phase 1 security association remains active.

IKE Phase 1 establishes a secure authenticated management channel between VPN peers. It protects the negotiation process by providing peer authentication, cryptographic protection and secure key establishment.

9.2 IPsec Phase 2 Parameters

Parameter	Recommended Value	Purpose
Encryption	AES-256	Encrypts actual business data.
Integrity	SHA-256	Detects modification of protected packets.
PFS	DH Group 14	Provides stronger independent keying.
Lifetime	3600 seconds	Regularly refreshes the security association.

Phase 2 establishes the IPsec security associations that protect the actual data traffic between the Head Office and each gallery. Encryption provides confidentiality, while integrity mechanisms help detect modification.

9.3 Parameter Summary

AES-256 → **Confidentiality**. It encrypts protected traffic. **SHA-256** → **Integrity**. It helps detect modification. **DH Group 14** → **Key exchange**. It supports secure establishment of shared secret material. **Authentication** → **Peer trust**. It ensures the VPN endpoint is authorized to participate in the tunnel.

10. Device-Hardening Checklist

Every router and switch should be hardened to prevent unauthorized management and reduce Layer-2 attack opportunities.

10.1 Disable Telnet and Enable SSH

```
hostname VASEWORTH-R1
ip domain-name vasesworth.local
username admin privilege 15 secret
crypto key generate rsa modulus 2048
ip ssh version 2
line vty 0 4
login local
transport input ssh
exit
```

The hostname identifies the device. The domain name supports RSA-key generation. A local privileged account provides authenticated administration. RSA keys enable SSH, and 'transport input ssh' prevents Telnet access on the VTY lines.

10.2 AAA Authentication

```
aaa new-model
aaa authentication login default local
username admin privilege 15 secret
```

AAA stands for Authentication, Authorization and Accounting. Authentication identifies the user, authorization determines permitted actions, and accounting records relevant administrative activity where supported.

10.3 Legal Warning Banner

```
banner motd #
WARNING: Authorized access only.
This system is the property of Vasesworth Glassblowing Studio & Gallery.
Unauthorized access or use is prohibited and may be monitored.
#
```

The banner warns users that the device is restricted to authorized personnel.

10.4 Disable Insecure or Unnecessary Services

```
no ip http server
no ip http secure-server

line vty 0 4
```

```
transport input ssh
```

Only required management services should remain enabled. Telnet should not be accepted on the VTY lines.

10.5 Secure Console Access

```
line console 0
login local
exec-timeout 5 0
exit
```

The console requires local authentication, and inactive sessions are automatically ended after the configured timeout.

10.6 Port Security

```
interface FastEthernet0/1
switchport mode access
switchport port-security
switchport port-security maximum 1
switchport port-security mac-address sticky
switchport port-security violation restrict
```

Port security limits which MAC addresses can use an access port. Sticky MAC learning can record the expected address, while a restrict action limits traffic when a violation occurs.

10.7 DHCP Snooping

```
ip dhcp snooping
ip dhcp snooping vlan 10

interface GigabitEthernet0/1
ip dhcp snooping trust
```

DHCP snooping helps prevent unauthorized DHCP responses and creates useful IP-to-MAC binding information. The legitimate DHCP/server-facing interface should be trusted; user access ports remain untrusted by default.

10.8 Unused Switch Ports

```
interface range FastEthernet0/10 - 24
shutdown
```

Unused switch ports should be disabled so that unauthorized devices cannot simply be connected to an unused physical port.

10.9 Layer-2 Protection for Incident 1

Port security, MAC restrictions, DHCP snooping, VLAN separation and monitoring reduce Layer-2 attack opportunities. These controls should be combined with appropriate device-specific ARP protection if supported by the deployed switch platform.

11. Wireless Security Design

11.1 Staff Wi-Fi

Recommendation: WPA3 + Staff VLAN. Staff users require access to legitimate business resources. WPA3 provides stronger wireless protection than older wireless security mechanisms.

11.2 Guest Wi-Fi

Recommendation: WPA2 + Guest VLAN when broad visitor-device compatibility is required. The guest network should be restricted to Internet access and must not have direct access to internal business resources. If all deployed guest infrastructure and client devices support WPA3, WPA3 can also be used.

11.3 Why Staff and Guest Networks Must Not Share a VLAN

If staff and visitors share one VLAN, visitor devices may gain Layer-2 visibility of internal devices and increase the risk of unauthorized access, scanning and ARP-based attacks. Separate VLANs provide logical network isolation.

Feature	Staff Wi-Fi	Guest Wi-Fi
Wireless security	WPA3	WPA2 (compatibility-focused design)
VLAN	Staff VLAN	Guest VLAN
Internal access	Permitted according to policy	Blocked
Internet access	Yes	Yes
Main objective	Protect business users/resources	Isolate untrusted visitors

12. ACL Considerations

Access Control Lists can provide an additional layer of network access control. The Guest VLAN should be prevented from accessing sensitive internal resources while appropriate Internet access is allowed. ACLs support least-privilege network communication and complement firewall policies.

```

Guest VLAN
|
v
ACL / Firewall
|
+----X----> Internal Servers
|
+-----> Internet

```

13. Security Controls Mapped to Threats

Threat	Main Defense	Expected Improvement
ARP spoofing	Port security, MAC restrictions, DHCP snooping, VLAN separation and Layer-2 monitoring	Reduces Layer-2 attack opportunities.
SYN flood	NGFW, stateful inspection and DoS/SYN protection	Improves availability of public services.
Phishing	Staff awareness, secure authentication and AAA	Reduces credential compromise.
Telnet exposure	Disable Telnet and use SSH	Protects management credentials.
Public Internet attacks	NGFW	Improves perimeter security.
Unencrypted site links	IPSec VPN	Protects confidentiality and integrity.
Guest access to internal network	Separate Guest VLAN and ACL policy	Reduces unauthorized internal access.
Unauthorized switch access	Port security and unused-port shutdown	Restricts unknown devices.

14. Implementation Plan

Phase 1 – Incident Response

- Investigate the ARP spoofing incident.
- Check switch MAC and ARP information.
- Identify suspicious devices.
- Secure affected switch ports.
- Reset potentially compromised credentials.

Phase 2 – Device Hardening

- Disable Telnet.
- Enable SSH.
- Configure AAA.
- Configure administrator accounts.
- Configure warning banners.
- Disable unnecessary services.
- Shut down unused switch ports.

Phase 3 – Network Security

- Configure Staff and Guest VLANs.
- Configure switch security.
- Configure DHCP snooping where appropriate.
- Apply ACLs.
- Implement wireless security.

Phase 4 – Firewall Deployment

- Deploy NGFW at Internet edge.
- Protect public-facing web services.
- Configure stateful firewall policies.
- Restrict unnecessary inbound traffic.
- Monitor suspicious connections.

Phase 5 – VPN Deployment

- Configure the HQ VPN endpoint.
- Configure Gallery 1, Gallery 2 and Gallery 3 VPN peers.
- Establish IKE Phase 1.
- Establish IPSec Phase 2.
- Verify encrypted communication.

Phase 6 – Awareness

- Train staff to identify phishing.
- Explain credential protection.
- Explain the danger of suspicious links.
- Establish a procedure for reporting suspicious messages.

15. Verification and Testing

15.1 SSH Verification

```
show ip ssh
show running-config | section line vty
```

These commands verify SSH status and VTY configuration. Telnet should not be permitted.

15.2 AAA Verification

```
show running-config | include aaa
```

Confirms AAA-related configuration.

15.3 Port Security Verification

```
show port-security
```

Verifies port-security status.

15.4 DHCP Snooping Verification

```
show ip dhcp snooping
```

Verifies DHCP snooping configuration.

15.5 VLAN Verification

```
show vlan brief
```

Verifies Staff and Guest VLANs.

15.6 Trunk Verification

```
show interfaces trunk
```

Verifies trunk interfaces and VLAN information where trunking is used.

15.7 IPSec Verification

```
show crypto isakmp sa  
show crypto ipsec sa
```

These commands can be used on supported Cisco IOS/IPSec implementations to verify IKE/IPSec security associations and protected traffic.

16. Security Testing Scenarios

Test	Expected Result
Attempt Telnet management access	Telnet is blocked.
Attempt SSH using valid credentials	Secure management access succeeds.
Guest device attempts to access an internal staff resource	Access is blocked.
Authorized staff device accesses permitted internal resources	Access succeeds according to policy.
Unauthorized device connects to a protected access port	Port-security policy detects/restricts the violation.
Traffic is sent between Head Office and a gallery	Traffic passes through the IPSec tunnel.

17. Staff Awareness Note

Cybersecurity is not only the responsibility of the IT team. Every employee plays an important role in protecting Vaseworth's network and business information. Be careful when opening emails or clicking links, especially messages that urgently request passwords, account verification or IT-support actions. Before entering credentials, verify that the website and sender are genuine. Never share a password or enter it into a suspicious page. If an email or login request looks unusual, stop and contact the IT team through an approved communication method. Even strong firewalls, VPNs and secure devices cannot completely prevent an employee from voluntarily giving credentials to an attacker, which is why security awareness and responsible user behavior are essential.

18. Security Improvement Plan

Security Layer	Implementation	Risk Addressed
Perimeter security	NGFW at Internet edge	Public Internet attacks and DoS.
Secure communication	IPSec VPNs	Unencrypted site-to-site traffic.
Device security	SSH, AAA, strong authentication, disabled insecure services	Credential exposure and unauthorized management.
Layer-2 security	Port security, MAC controls, DHCP snooping	ARP-related and unauthorized-device risks.
Network segmentation	Separate Staff and Guest VLANs	Guest-to-internal access.
Wireless security	WPA3 for staff; isolated guest wireless	Wireless compromise and lateral access.
User awareness	Phishing training and reporting process	Credential compromise.

19. Conclusion

The Vaseworth Glassblowing Studio & Gallery case demonstrates how multiple security threats can affect different aspects of an organization's network. The four incidents were identified as ARP spoofing/MITM, SYN flood/DoS, phishing/credential compromise and cleartext Telnet management exposure.

An NGFW is recommended at the Internet-facing edge because public-facing gallery services have greater exposure to Internet-based attacks. Stateful firewall controls can be used for predictable internal and site-to-site traffic where the risk and inspection requirements are lower. Site-to-site IPSec VPNs protect communication between Head Office and each gallery over the public Internet.

Network devices should be hardened by disabling Telnet, enabling SSH, configuring AAA, using strong administrative authentication, displaying a legal warning banner, disabling unnecessary services and applying switch-security controls. Staff and guest wireless networks should be separated using VLANs, with stronger wireless security for staff and isolated guest access.

Finally, technical controls must be supported by employee awareness. Phishing demonstrates that even a well-secured network can be compromised if users unknowingly provide credentials to attackers. A layered security approach combining firewalls, VPNs, secure device management, Layer-2 security, VLAN segmentation, wireless security and staff awareness provides a practical security improvement plan aligned with the identified risks.

20. Deliverables Checklist

Required Deliverable	Report Location	Status
Incident-to-CIA mapping table	Section 5	Included
Firewall architecture with justification	Sections 7–8	Included
Site-to-site VPN design sheet	Section 9	Included
Device-hardening checklist	Section 10	Included
Wireless security design	Section 11	Included
Non-technical staff-awareness note	Section 17	Included